

Индивидуальный проект

5 Этап. Использование Burp Suite

Панина Жанна Валерьевна

2026-05-10

Содержание I

- 1 Информация
- 2 Вводная часть
- 3 Основная часть
- 4 Результаты

Раздел 1

Информация

- Панина Жанна Валерьевна

- Панина Жанна Валерьевна
- студентка НКАбд-02-24

- Панина Жанна Валерьевна
- студентка НКАбд-02-24
- Российский университет дружбы народов им. П. Лумумбы

- Панина Жанна Валерьевна
- студентка НКАбд-02-24
- Российский университет дружбы народов им. П. Лумумбы
- 1132246710@rudn.ru

- Панина Жанна Валерьевна
- студентка НКАбд-02-24
- Российский университет дружбы народов им. П. Лумумбы
- 1132246710@rudn.ru
- https://github.com/zvpanina/study_2025-2026_infosec-intro

Раздел 2

Вводная часть

Цель работы

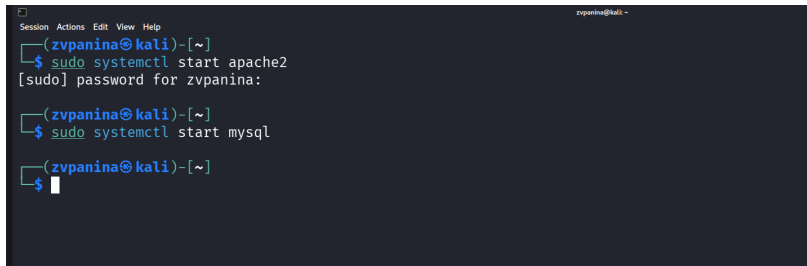
Научиться использовать инструмент Burp Suite.

Burp Suite представляет собой набор мощных инструментов безопасности веб-приложений, которые демонстрируют реальные возможности злоумышленника, проникающего в веб-приложения. Эти инструменты позволяют сканировать, анализировать и использовать веб-приложения с помощью ручных и автоматических методов. Интеграция интерфейсов этих инструментов обеспечивает полную платформу атаки для обмена информацией между одним или несколькими инструментами, что делает Burp Suite очень эффективной и простой в использовании платформой для атаки веб-приложений.

Раздел 3

Основная часть

Запускаю локальный сервер для дальнейшего тестирования Burp Suite.



```
Session Actions Edit View Help
zvpanina@kali ~
(zvpanina@kali)-[~]
$ sudo systemctl start apache2
[sudo] password for zvpanina:

(zvpanina@kali)-[~]
$ sudo systemctl start mysql

(zvpanina@kali)-[~]
$
```

Рисунок 1: Запуск mysql и apache2

Запускаю инструмент Burp Suite.

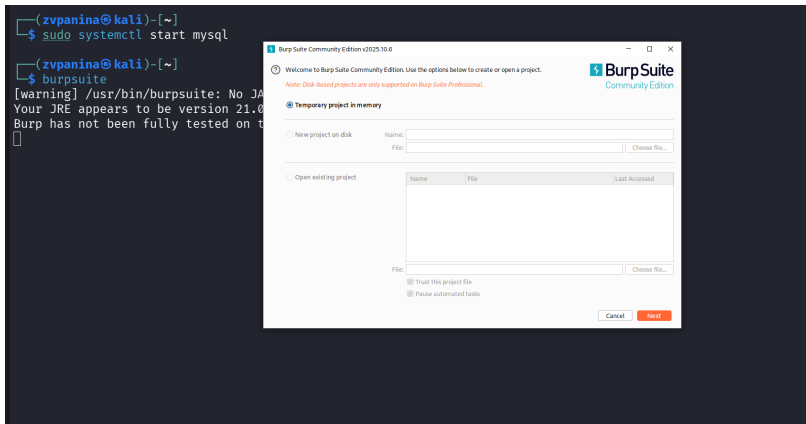


Рисунок 2: Запуск Burp Suite

Открываю сетевые настройки браузера для подготовки к работе.

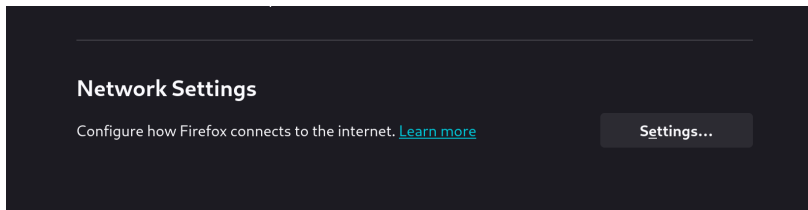
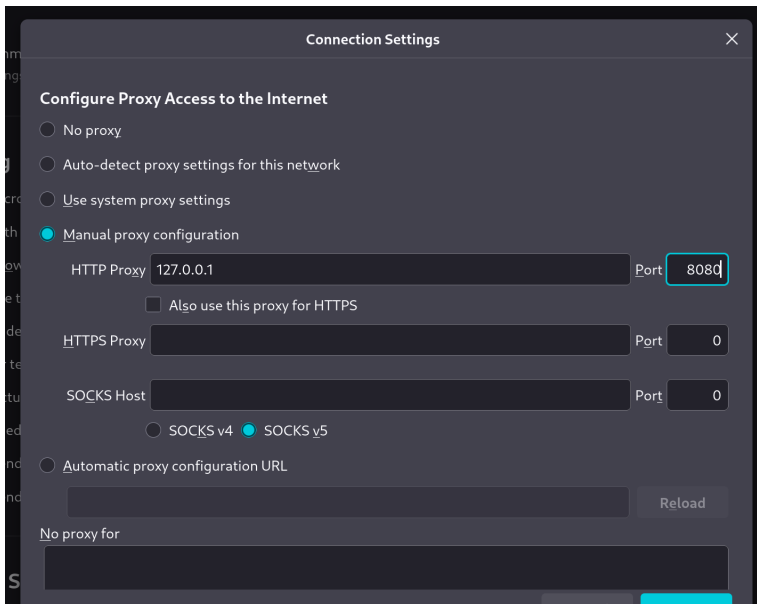


Рисунок 3: Сетевые настройки браузера

Изменяю настройки сервера для работы с прокси и захвата данных с помощью Burp Suite.



Изменяю настройки Proxu в Burp Suite для дальнейшей работы.

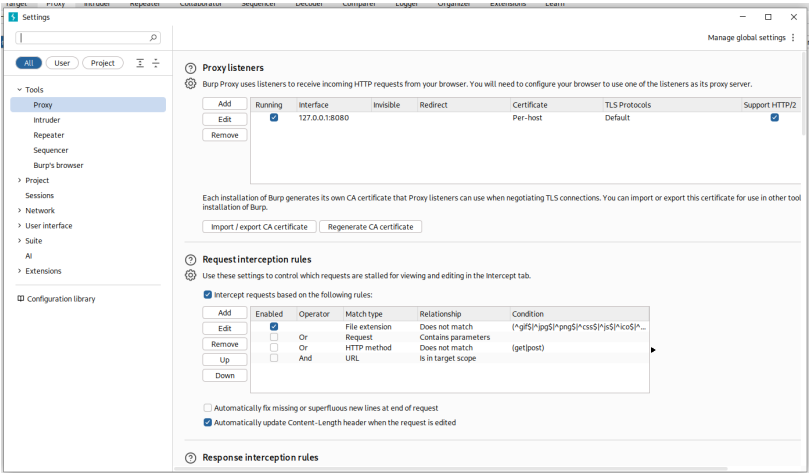


Рисунок 5: Изменение настроек Proxu

Во вкладке Proxy устанавливаю значение «Intercept» на «on».

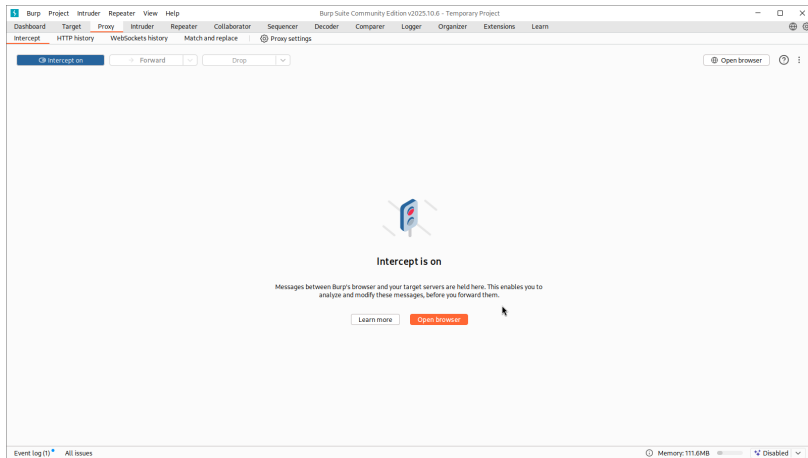


Рисунок 6: Включение Intercept

Устанавливаю параметр `network_allow_hijacking_localhost` на `true`, чтобы Burp Suite корректно работал с локальным сервером.

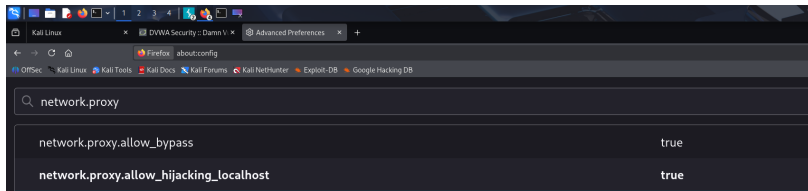


Рисунок 7: Параметр `network_allow_hijacking_localhost`

Пытаюсь зайти в браузере на DVWA, сразу во вкладке Proxu вижу захваченный запрос. Нажимаю «Forward» для загрузки страницы.

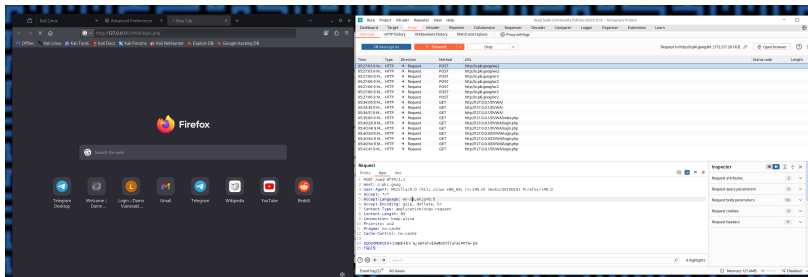


Рисунок 8: Захваченный запрос

Сразу загрузилась страница авторизации и поменялся текст запроса.

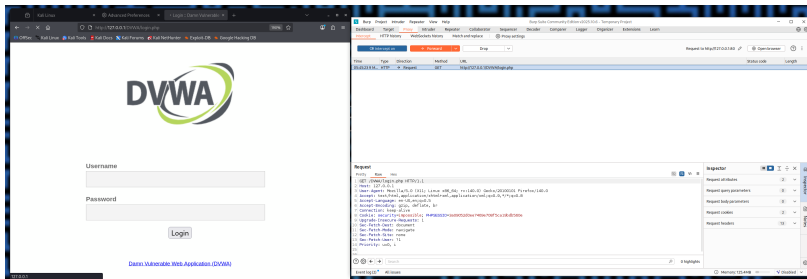


Рисунок 9: Страница авторизации и изменения

Можем перейти на вкладку Target, чтобы посмотреть историю запросов.

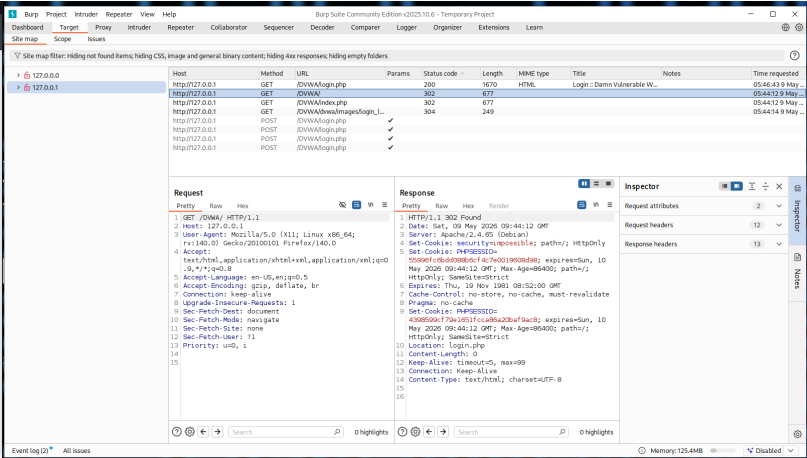


Рисунок 10: Вкладка Target

Ввожу неверные случайные данные для входа, пытаюсь залогиниться и вижу в запросе строку, в которой отображаются введенные мной данные.

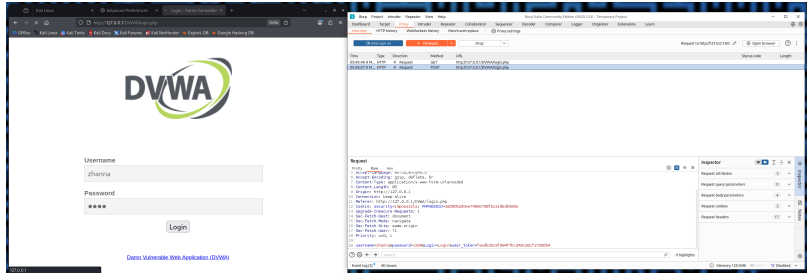


Рисунок 11: Попытка входа

Этот запрос можем также найти во вкладке Target, нажав правой кнопкой мыши на хост нужного запроса и далее «Send to Intruder».

The screenshot displays the Burp Suite interface. At the top, the 'Intruder' tab is active. Below the menu bar, there are buttons for 'Intercept on', 'Forward', and 'Drop'. A table lists intercepted requests:

Time	Type	Direction	Method	URL
05:46:46 9 M...	HTTP	→ Request	GET	http://127.0.0.1/DVWA/login.php
05:48:07 9 M...	HTTP	→ Request	POST	http://127.0.0.1/DVWA/login.php
05:53:45 9 M...	HTTP	→ Request	GET	http://127.0.0.1/DVWA/login.php
05:53:48 9 M...	HTTP	→ Request	POST	http://127.0.0.1/DVWA/login.php

The 'Request' tab is selected, showing the raw data of the selected POST request. A context menu is open over the request, with 'Send to Intruder' highlighted. The menu also includes options like 'Send to Repeater', 'Send to Sequencer', 'Send to Comparer', 'Send to Decoder', 'Send to Organizer', 'Insert Collaborator payload', 'Request in browser', and 'Engagement tools [Pro version only]'. The request body is visible in the bottom pane, showing a login attempt with username 'zhanna' and password '123'.

Переходим на вкладку Intruder, видим свой запрос и значение по умолчанию у типа атаки.

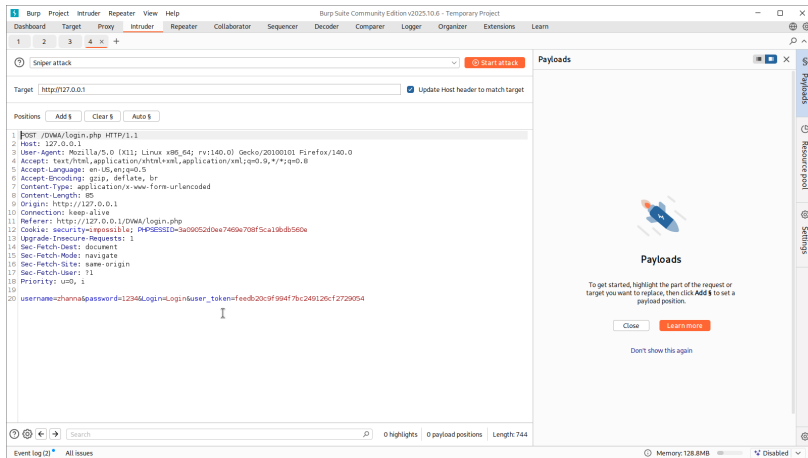


Рисунок 13: Вкладка Intruder

Изменяем значение типа атаки на Cluster Bomb attack и проставляем специальные символы у имени пользователя и пароля - эти данные и будем пробивать.

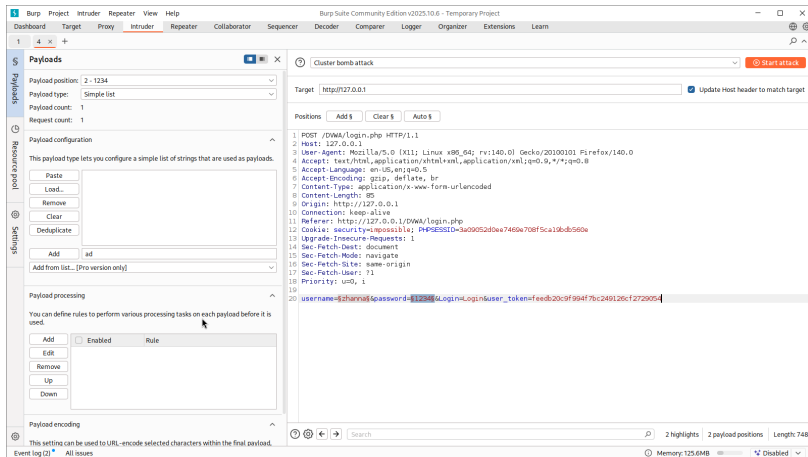


Рисунок 14: Изменение типа атаки

Составляем два списка со значениями для подбора в Payload setting - сначала первый

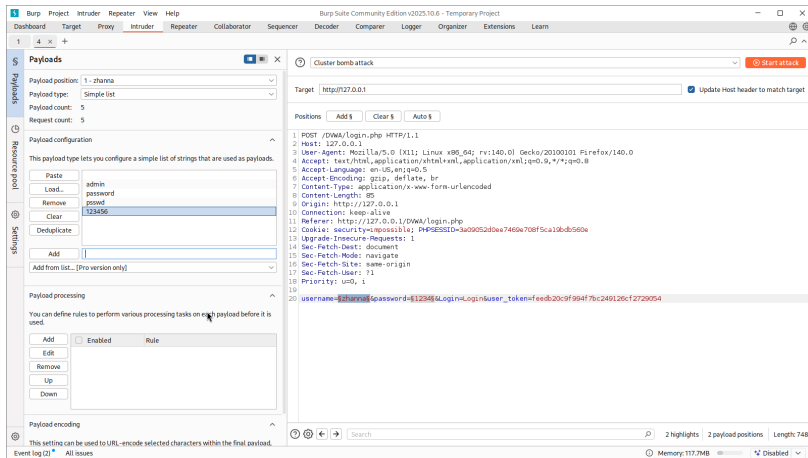


Рисунок 15: Первый список со значениями

Затем второй. В строке Request count видим число - это нужное количество запросов, чтобы проверить все возможные пары пользователь-пароль.

The screenshot displays the Burp Suite interface with the 'Payloads' tab selected. The left sidebar contains icons for 'Payloads', 'Resource pool', and 'Settings'. The main area is divided into two sections: 'Payload configuration' and 'Payload processing'.

Payload configuration:

- Payload position: 2 - 1234
- Payload type: Simple list
- Payload count: 5
- Request count: 25

Payload configuration details:

This payload type lets you configure a simple list of strings that are used as payloads.

Buttons: Paste, Load..., Remove, Clear, Deduplicate, Add.

Current payload list:

- admin
- password
- 12345678
- abcdefg

Payload processing:

You can define rules to perform various processing tasks on each payload before it is used.

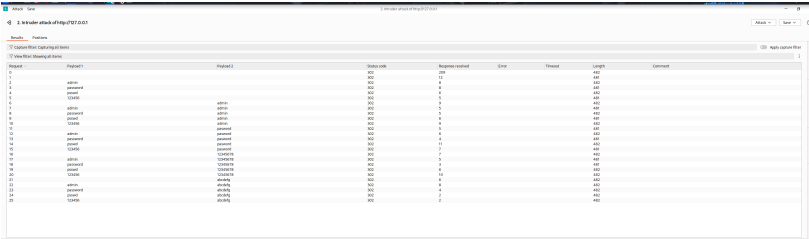
Cluster bomb attack configuration:

- Target: http://127.0.0.1
- Positions: Add \$, Clear \$

Attack details:

```
1 POST /DWA/login.php HTTP/1.1
2 Host: 127.0.0.1
3 User-Agent: Mozilla/5.0 (X11; Linux i686; rv:1.9.0.1) Gecko/20100101 Firefox/3.0.1
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.8
6 Accept-Encoding: gzip, deflate
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 85
9 Origin: http://127.0.0.1
10 Connection: keep-alive
11 Referer: http://127.0.0.1/DWA/login.php
12 Cookie: security=impossible
13 Upgrade-Insecure-Requests: 1
14 Sec-Fetch-Dest: document
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-Site: same-origin
17 Sec-Fetch-User: ?1
18 Priority: u=0, i
19
20 username=$zhanna$&password=
```

Нажимаю start attack, и начинается подбор.



The screenshot shows the Burp Suite interface with the 'HTTP history' tab selected. The table displays the following data:

Request	Response	Status code	Response received	Error	Timeout	Length	Comment
0		302	200			480	
1		302	12			480	
2	admin	302	8			480	
3	password	302	8			480	
4	password	302	8			480	
5	123456	302	5			480	
6	admin	302	9			480	
7	password	302	5			480	
8	password	302	5			480	
9	password	302	8			480	
10	123456	302	8			480	
11	password	302	5			480	
12	admin	302	8			480	
13	password	302	11			480	
14	password	302	7			480	
15	123456	302	5			480	
16	admin	302	9			480	
17	password	302	5			480	
18	password	302	8			480	
19	123456	302	10			480	
20	admin	302	8			480	
21	password	302	4			480	
22	123456	302	2			480	
23	admin	302	2			480	
24	password	302	2			480	
25	123456	302	2			480	

Рисунок 17: Запуск атаки

При открытии результата каждого post-запроса можем увидеть полученный get-запрос: по нему видно, куда нас перенаправило после выполнения ввода пары пользователь-пароль. Например, в случае с подбором пары password-abcdefg нас перенаправило на login.php, это значит, что пара не подходит.

Results - Positions							
Y Capture Filter: Capturing all items							
Y View Filter: Showing all items							
Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length
0			302	209			482
1			302	12			481
2	admin		302	8			482
3	password		302	8			481
4	passwd		302	8			482
5	123456		302	5			481
6		admin	302	9			482
7		admin	302	5			481
8	password	admin	302	5			482
9	passwd	admin	302	6			481
10	123456	admin	302	9			482
11		password	302	5			481
12		password	302	202			482
13	password	password	302	4			481
14	passwd	password	302	11			482
15	123456	password	302	7			481
16		12345678	302	7			482
17	admin	12345678	302	5			481
18	password	12345678	302	5			481
19	passwd	12345678	302	6			482
20	123456	12345678	302	10			482
21		abcdefg	302	8			482
22		abcdefg	302	8			482
23	password	abcdefg	302	4			482
24	passwd	abcdefg	302	2			482
25	123456	abcdefg	302	2			482

Request - Response			
Pretty	Raw	Hex	Render
1: HTTP/1.1 302 Found			
2: Date: Sat, 10 May 2020 10:16:50 GMT			
3: Server: Apache/2.4.18 (Ubuntu)			
4: Expires: Thu, 10 Nov 1981 08:52:50 GMT			
5: Cache-Control: no-store, no-cache, must-revalidate			
6: Pragma: no-cache			
7: Set-Cookie: PHPSESSID=6b7e15ab66f954cfc671d899f73907; expires=Sun, 10 May 2020 10:16:50 GMT; Max-Age=86400; path=/; HttpOnly; SameSite=Strict			
8: Location: login.php			
9: Content-Length: 0			
10: Keep-Alive: timeout=5, max=100			
11: Connection: Keep-Alive			
12: Content-Type: text/html; charset=UTF-8			
13:			
14:			

Рисунок 18: Результаты подбора

Проверяем результат пары admin-password во вкладке Response; здесь нас перенаправило на страницу index.php, значит, эта пара верна.

AttackSave3. Intruder attack of http://127.0.0.1

ResultsPositions

▼ Capture filter: Capturing all items

▼ View filter: Showing all items

Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length
0			302	3			482
1			302	4			482
2	admin		302	6			482
3	password		302	5			482
4	123456		302	1			481
5			302	3			482
6		admin	302	5			482
7	admin	admin	302	4			481
8	password	admin	302	5			482
9	password	password	302	4			481
10	admin	123456	302	5			482
11		password	302	6			481
12	admin	password	302	6			482
13	password	password	302	1			481
14	password	password	302	5			482
15	123456	password	302	5			482
16		12345678	302	3			482
17	admin	12345678	302	4			482
18	password	12345678	302	5			482
19	password	12345678	302	5			482
20	123456	12345678	302	1			482
21		abcdifg	302	2			482
22	admin	abcdifg	302	1			482
23	password	abcdifg	302	2			482
24	password	abcdifg	302	1			482
25	123456	abcdifg	302	0			482
26		password	302	2			482
27	admin	password	302	2			482
28	password	password	302	4			482
29	password	password	302	5			482
30	123456	password	302	3			482

RequestResponse

▼

Hosts: 127.0.0.1 302 Found

1: HTTP/1.1 302 Found

2: Date: Sat, 09 May 2020 10:21:37 GMT

3: Server: Apache/2.4.18 (Ubuntu)

4: Expires: Thu, 09 May 1980 00:00:00 GMT

5: Cache-Control: no-store, no-cache, must-revalidate

6: Pragma: no-cache

7: Set-Cookie: PHPSESSID=01051d9f706cbb7d9228b9db19a302240; expires=Sun, 10 May 2020 10:21:37 GMT; Max-Age=604800; path=/; HttpOnly; SameSite=Strict

8: Location: index.php

9: Content-Length: 0

10: Keep-Alive: timeout=5, max=100

11: Connection: Keep-Alive

12: Content-Type: text/html; charset=UTF-8

13:

14:

Рисунок 19: Правильно подобранная пара

Если хотим дополнительно проверить с помощью Repeater, нажимаем правой кнопкой мыши на интересующий нас запрос и выбираем «Send to Repeater».

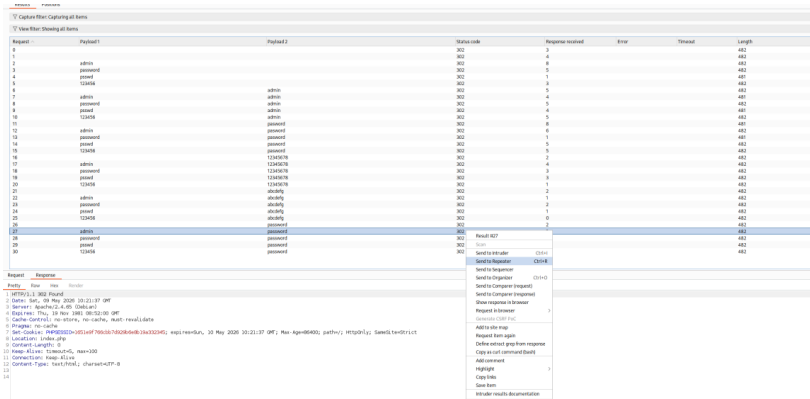


Рисунок 20: Проверка через Repeater

Перехожу во вкладку «Repeater».

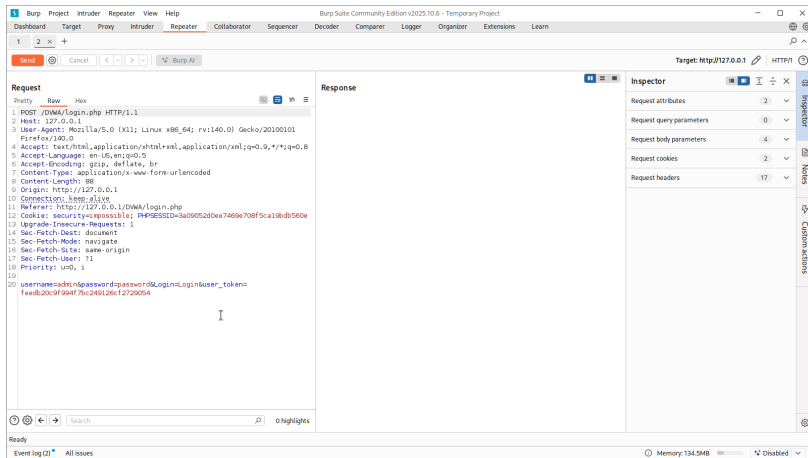


Рисунок 21: Вкладка Repeater

Нажав кнопку «send», получаю в «Response» в строке Location перенаправление на index.php.

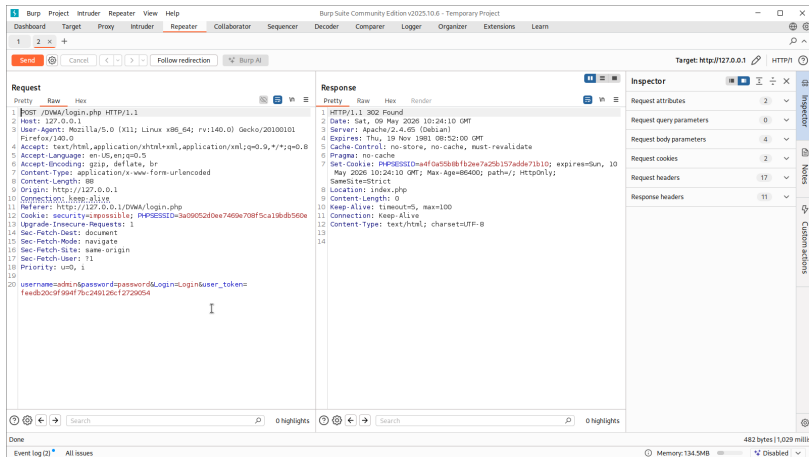


Рисунок 22: Просмотр Response

Нажав на Follow redirection, получаю неcompiled html-код в окне Response.

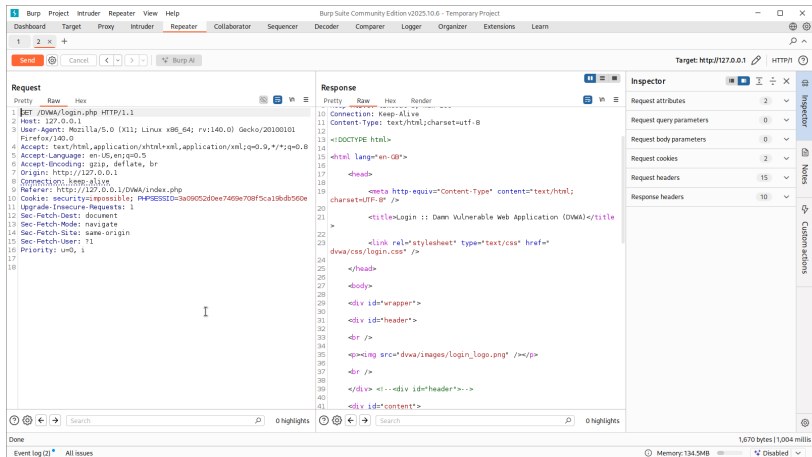


Рисунок 23: html код

Захожу в окно Render и вижу изображение полученной страницы.

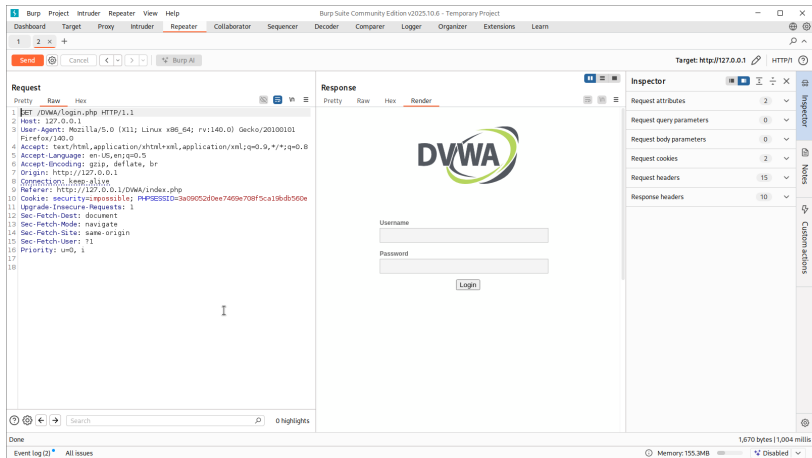


Рисунок 24: Как выглядит полученная страница в Render

Раздел 4

Результаты

При выполнении данной работы я научилась использовать инструмент Burp Suite.